



Plan de Continuidad

Gobierno de TI | IT Governance

Profesora: Palacios Solano Rocío

Grupo 7CV4

Elaboró: Rojo Ibarra Jesús

Periodo Escolar 26/2

Fecha de entrega: 17 de junio de 2026

1. Fecha de elaboración

1 4 0 6 2 0 2 6

2. Introducción

El Plan de Continuidad del Negocio tiene como objetivo garantizar la operación del Servicio de Seguridad Ofensiva ante eventos disruptivos que puedan afectar la disponibilidad, integridad o confidencialidad de los activos de información.

Este plan se apoya en el análisis de impacto al negocio (BIA), la matriz de riesgos y el inventario de activos, con el fin de establecer estrategias de respuesta, recuperación y continuidad que permitan minimizar interrupciones y asegurar la prestación del servicio a los clientes.

3. Objetivo del Plan de Continuidad

Garantizar la continuidad operativa del Servicio de Seguridad Ofensiva ante incidentes tecnológicos, de seguridad o infraestructura, estableciendo acciones claras de respuesta y recuperación que permitan mantener los niveles de servicio acordados y reducir el impacto al negocio.

4. Alcance del Plan

Este plan aplica a los procesos críticos del Servicio de Seguridad Ofensiva, incluyendo:

- Planeación y definición de alcance (RoE)
- Ejecución de pruebas ofensivas (pentesting, vulnerabilidades, phishing)
- Análisis, reporte y cierre de hallazgos
- Gestión de evidencias, informes y datos sensibles del cliente
- Comunicación con clientes y entrega de resultados

El plan cubre incidentes relacionados con infraestructura (VPS, estaciones de trabajo), software (herramientas de pentesting), seguridad de la información, fallas operativas, indisponibilidad de personal y eventos externos.

5. Procesos Críticos Identificados

Proceso	Nivel de criticidad
Planeación y definición de alcance (RoE)	Alto
Ejecución de pruebas ofensivas (pentesting)	Crítico
Análisis, reporte y cierre	Alto
Gestión de evidencias y hallazgos	Crítico
Entrega segura de informes al cliente	Alto

6. Escenarios de Interrupción

Escenario 1: Falla en infraestructura VPS / Cloud

- Impacto: Interrupción de escaneos de vulnerabilidades, pruebas de penetración y campañas de phishing.
- Procesos afectados: Ejecución de pruebas ofensivas, análisis de resultados.
- Activos involucrados: VPS, herramientas de pentesting, plataforma de phishing, almacenamiento cifrado.

Escenario 2: Incidente de seguridad ó fuga de información

- Impacto: Exposición de hallazgos, vulnerabilidades descubiertas o datos sensibles del cliente. Riesgo legal y reputacional alto.
- Procesos afectados: Gestión de evidencias, análisis y reporte, entrega de informes.
- Activos involucrados: Bases de datos de vulnerabilidades, almacenamiento de evidencias, informes finales.

Escenario 3: Indisponibilidad del personal clave

- Impacto: Retrasos en la ejecución de pruebas, atención a clientes y entrega de resultados.
- Procesos afectados: Ejecución de pruebas ofensivas, análisis y reporte, comunicación con clientes.

- Activos involucrados: Ingeniero de Seguridad Ofensiva (Pentester), Analista de Vulnerabilidades, Líder de Proyecto.

Escenario 4: Falla en estaciones de trabajo locales

- Impacto: Imposibilidad de realizar documentación, análisis de hallazgos o generación de reportes.
- Procesos afectados: Análisis de resultados, elaboración de informes, clasificación CVSS.
- Activos involucrados: Estaciones de trabajo del equipo ofensivo, herramientas locales, plantillas de reportes.

Escenario 5: Interrupción de conectividad a internet

- Impacto: Imposibilidad de ejecutar pruebas remotas, comunicarse con clientes o acceder a plataformas en la nube.
- Procesos afectados: Ejecución de pruebas ofensivas, comunicación con clientes, entrega de informes.
- Activos involucrados: Servicio de internet (ISP), VPS, plataforma de phishing.

7. Estrategias de Continuidad y Recuperación

Escenario	Estrategia de Continuidad
Falla en infraestructura VPS / Cloud	Uso de infraestructura alternativa (VPS secundario) o ejecución desde entornos locales aislados. Respallos semanales de configuraciones.
Incidente de seguridad ó fuga de información	Activación del plan de respuesta a incidentes, aislamiento de activos comprometidos, notificación al cliente, destrucción segura de datos expuestos.
Indisponibilidad del personal clave	Restauración desde respaldos cifrados (diarios). Almacenamiento redundante en disco externo cifrado.
Falla en estaciones de trabajo locales	Redistribución de roles. Todo el equipo cuenta con conocimientos transversales. Contar con al menos 2 pentesters certificados.
Falla de estaciones de trabajo locales	Equipos de respaldo disponibles. Documentación y plantillas almacenadas en la nube (cifrada) y en disco externo.
Interrupción de conectividad a internet	Conexión de respaldo (ISP alternativo). Ejecución de pruebas en modo offline con herramientas locales. Comunicación telefónica con clientes.

8. Tiempos de Recuperación (RTO / RPO)

Proceso / Actividad	RTO	RPO
Ejecución de pruebas ofensivas	5 horas	5 horas
Análisis y clasificación de hallazgos	3 horas	4 horas
Elaboración de informes	5 horas	12 horas
Gestión de evidencias y almacenamiento cifrado	2 horas	1 hora
Comunicación con clientes y entrega de resultados	4 horas	-
Plataforma de phishing	5 horas	24 horas
Herramientas de pentesting (diversas)	2 horas	24 horas

9. Roles y Responsabilidades

Rol	Responsabilidad
Líder de Proyecto	Activar el plan de continuidad, coordinar la respuesta, comunicarse con clientes, supervisar la recuperación.
Ingeniero de seguridad ofensiva (pentester)	Recuperar la ejecución de pruebas, restaurar herramientas, validar hallazgos.
Analista de vulnerabilidades	Restaurar bases de datos de vulnerabilidades, apoyar en escaneos y validación de falsos positivos.
Soporte técnico	Restaurar infraestructura (VPS, almacenamiento, conectividad), aplicar parches de seguridad.
Responsable de seguridad	Contener y analizar incidentes de seguridad, coordinar destrucción segura de datos si aplica.

10. Pruebas y Actualización del Plan

El Plan de Continuidad será probado al menos una vez al año mediante simulacros de interrupción controlados, incluyendo:

- Simulación de falla de VPS/infraestructura
- Simulación de pérdida de evidencias
- Simulación de indisponibilidad de personal clave

Cualquier cambio en los procesos críticos, infraestructura, herramientas, personal o riesgos identificados (actualización de matriz de riesgos o BIA) deberá reflejarse en una actualización del plan dentro de los 15 días hábiles siguientes.

El plan será revisado y aprobado por el Líder de Proyecto y el Responsable de Seguridad.